

作业 8：权衡、整合与治理

《负责任人工智能：原则、治理与量化方法》

黄斐，新南威尔士大学

姓名：林富强 专业：软件工程

场景说明：软件缺陷预测系统（沿用第一章作业场景）

本作业沿用我在第一章作业中定义的应用场景：软件缺陷预测系统，并在全部四道题中保持一致。场景描述：一家软件公司构建机器学习模型，根据代码变更的静态度量（代码行数 LOC、圈复杂度、测试覆盖率）、历史缺陷数据以及开发者行为特征（提交时段、提交频率、返工次数），预测某次代码变更或模块在未来出现缺陷的概率，并输出“高风险标记”。被标记的变更将被强制增加人工评审、延长测试，极端情况下推迟发布。

术语说明（面向非软件领域读者）：**圈复杂度**是衡量一个函数中独立执行路径数量的指标，数值越高说明代码分支越多、越难被测试覆盖；**提交**指开发者把一次代码修改保存进版本库的操作。该系统直接影响开发者的工作负荷与职业评价（被标记意味着更多评审与更慢的发布），属于对个人有重大影响的高风险自动化决策，但课堂讲授中未讨论过该场景。

问题一：生命周期案例研究与技术选择

下面对软件缺陷预测系统逐一梳理六个生命周期阶段：每个阶段先列出涉及的公平性、可解释性与隐私考量（a），再指出在该阶段部署的一项来自第 2–7 章的具体技术及选择理由（b）。

阶段 1：问题定义

a. 伦理考量：

- **公平性**：高风险标记会转化为额外评审与发布延迟，必须预先确定哪项公平性准则适用于“标记在团队、资历与工作模式之间的分布”，并识别可能因错误而不成比例受影响的群体——例如只能夜间与周末提交代码、承担更多家庭责任的开发者。
- **可解释性**：发布门禁属于高风险决策，需在此阶段决定采用内在可解释的模型（如逻辑回归），还是“黑箱模型 + 事后解释”——这一选择一旦做出，后续阶段的解释义务范围随之固定。
- **隐私与问责**：开发者行为数据的收集目的与法律依据须在此划定（明确该系统不得用于绩效评估或人事决策）；若模型漏检缺陷导致线上事故，或错误标记拖慢了本应快速上线的修复，须明确由谁承担责任。

b. 部署技术：在建模之前从第 2 章选定公平性准则与模型设计目标 MCDP（条件人口统计学均等性），并连同预设审计规程一并写入需求文档。理由：无约束的 M0 与“通过无知实现公平”的 MU 都挡不住代理变量歧视；MDP 要求所有模块的标记率完全均等，会抹掉模块类型间的真实风险差异（支付模块的改动天然比配置文件改动风险高）；MCDP 在“合法分组”（模块类型、变更规模）内部要求高风险标记率均等，既承认合理差异，又约束结构性歧视。准则必须在看到数据之前固定，避免“先建模型、再挑一个过得去的公平性指标”的事后操纵空间。

阶段 2：数据收集

a. 伦理考量：

- **隐私：**提交时间戳、提交频率等行为数据可以推断开发者的作息、加班强度乃至健康状况；“精确时间戳 + 作者 + 模块”构成准标识符组合，在公司内部掌握花名册与全部背景信息的条件下，重新识别门槛极低。还须审查收集是否满足数据最小化与目的限制。
- **公平性：**历史缺陷标签并非中性的“事实”——过去的测试资源如何分配，决定了哪些模块、哪些团队的 bug 更容易被记录在案。标签本身可能携带历史性偏见，模型会忠实地延续这种偏见。

b. 部署技术：准标识符分析与数据最小化（第 6–7 章，sdcMicro 的评估思路）。对训练与审计数据集评估“时间戳 + 作者 + 模块”等组合的重新识别风险，将精确到分钟的时间戳泛化为时段桶（如“工作时段 / 深夜 / 周末”），并剔除与预测目标无关的字段。理由：该数据集的敏感主体是开发者本人，且数据的实际控制者（公司）恰好掌握最完整的背景信息；而泛化时段几乎不损失预测信号——缺陷风险与“深夜”这一粗粒度事实相关，与“23:47”这个精确时刻无关。

阶段 3：模型开发

a. 伦理考量：

- **公平性：**识别代理变量——深夜提交占比、提交频率等行为特征与年龄、家庭责任等受保护属性相关，即使受保护属性从未被收集，歧视仍可经这些通路传导；须在训练中落实阶段 1 选定的 MCDP 准则。
- **可解释性：**模型选型须平衡性能与可解释程度，确保解释输出达到被评估开发者与内部审计所要求的水平；**隐私：**评估训练环节是否需要隐私增强技术（本场景数据不出组织，治理性控制即可，见阶段 2）。

b. 部署技术：MCDP 去偏（第 2–3 章）——在合法分组内对训练数据重加权，使高风险标记率在分组内不依赖代理行为特征，同时保留代码度量等合法预测信号的完整使用权。理由：FTU（直接剔除“深夜提交占比”）只会让歧视转入 LOC、提交频率等其他代理变量——第 2 章的核心结论是“剔除受保护属性不保证输出独立”；MCDP 直接在输出层面施加约束，并配合第 4–5 章的 PDP/SHAP 检查是否存在残余代理通路。

阶段 4：模型验证

a. 伦理考量：

- **公平性：**目标是为“模型满足所选准则”提供正面证明，而不是仅仅“未能检测出违规”；**可解释性：**解释输出须与已知变量效应交叉核实（例如圈复杂度的效应曲线应当单调递增，若出现反常平台须排查数据或特征问题）。
- **隐私与稳定性：**若审计数据集需提供给外部审计方，须先做重新识别风险评估；模型还须在跨项目、跨时间段的样本外数据上验证稳定性，而非只在整体指标上达标。

b. 部署技术：预设审计规程 + TOST 等效性检验（配 HC3 异方差稳健标准误）（第 2–3 章）。

在查看结果之前预先登记等效性边界（例如：合法分组内高风险标记率差异不超过 2 个百分点），再用 TOST 检验给出“差异落在边界内”的正面统计证据。理由：常规的“组间差异不显著 → 合规”推理把“未能检测出违规”当成了合规证据，在样本量小、检验功效不足时会系统性放行有偏模型；TOST 把举证责任反转——先声明多大的差异可容忍，再证明实际差异确实落在其中，这才是审计框架所要求的“合规性证据”。

阶段 5：部署

a. 伦理考量：

- **可解释性与可申诉性：**被标记的开发者有权获得解释（解释权）；高风险标记不得仅凭自动化决定生效，必须设有申诉复核渠道与人工干预点（对应《个人信息保护法》第 24 条的拒绝纯自动化决策权）。
- **公平性与隐私：**人工复核环节本身也需监测——复核员可能不加批判地“复制”模型偏见；解释内容不得泄露其他开发者的数据（如“与你同期提交该模块的其他人的平均缺陷率”这类聚合信息须谨慎）。

b. 部署技术：阈值化反事实解释（第 4–5 章），面向被标记的开发者。以“若圈复杂度降至 12 以下且新增测试覆盖达到 70%，该变更将不会被标记”的形式，给出具体、可据以行动的解除条件。理由：解释权的关键不是展示模型的内部权重，而是让受影响者同时知道“为什么”与“怎样可以改变结果”；反事实解释恰好同时满足两项，并且天然与评审流程衔接——解除条件即整改建议。

阶段 6：监测

a. 伦理考量：

- **公平性：**随着代码库与开发者群体的演变（新团队并入、新语言与框架引入、组织重构），合法分组的结构与分组间标记率差异都会漂移——部署时通过的 TOST 审计只代表当时，新出现的差异若无人重算就不会被发现。

- **可解释性**：模型每次再训练后，PDP 形状与反事实阈值都可能变化（例如重构实践普及后 LOC 与缺陷的关系改变），面向开发者的解除条件若不随之更新，会给出过时甚至错误的整改指引。

- **隐私**：存储限制须落实——开发者离职后其行为数据须按期删除；监测仪表板按分组展示统计时，小团队的统计量本身可能变成识别个体的通道（两三个人的团队，“该组标记率 50%”等于点名），须对小分组做抑制或聚合。

b. 部署技术：分层公平性监测与重新验证触发器（第 2–3 章审计框架的部署后延伸）。每月按合法分组重算高风险标记率并复核 TOST 边界，同时监测输入分布相对训练分布的漂移；任一指标越界即自动触发重新验证流程（暂停门禁自动化升级、启动回滚评估）。理由：阶段 1 固定的公平性准则只有在持续监测下才有意义——本讲义的核心结论正是“负责任 AI 是嵌入完整生命周期的持续过程，而非部署前一次性的核对清单”；此外还要警惕交互效应：重大流程变革（如引入结对编程）会同时改变行为特征分布与缺陷标签，单一指标的监测会被这种系统性变化误导，因此触发器须同时覆盖公平性、性能与漂移三类信号。

c. 一个阶段：为什么“显而易见”的选择在这里并不适用

我选取**阶段 5（部署）**。显而易见的默认做法是：对每个被标记的开发者给出 **SHAP 瀑布图**——第 4–5 章的旗舰局部解释工具（SHAP 把一次预测的输出分解为各特征对该次预测的贡献值）。但在本阶段的具体约束下，它并不是面向开发者的合适工具：

- **受众错位**。读懂 SHAP 瀑布图需要理解“相对基准预测的平均贡献”这一概念；而被解释对象是开发者（非技术受众），他们需要的是“我该怎么改”，而不是“该特征贡献了 +0.31”。

- **相关特征会扭曲归因（本课程自己验证过的教训）**。第 5 章作业已经实证：LOC 与圈复杂度高度相关，树模型会在二者之间任意分摊贡献，导致单条 SHAP 解释不稳定——同一变更更可能得到归因排序不同的两份解释。作为“解释权”的正式输出，这种不稳定性反而损害可信度。

- **计算成本与频率不匹配**。每次代码提交都可能触发标记；为高频、小粒度的门禁决策逐一计算并存储 SHAP 值是不必要的开销，而反事实条件可以从阶段 3 选定的内在可解释模型（逻辑回归）的系数直接推导，几乎零成本且精确无近似误差。

- **解释可能适得其反**。向开发者展示“深夜提交占比 +0.35”，实质上是告知“系统在监控你的加班时间”——监控本身合法，但作为解释输出会制造被监视感，并诱发对抗性行为（例如人为把提交改到白天），反而污染真实缺陷信号。

替代方案：解释按受众分流。面向开发者的解释权输出采用阈值化反事实规则（见阶段 5b），它面向非技术受众、稳定、可行动且近零成本；SHAP 与 PDP 则保留给它们真正合适的受众——内部评审团队与模型审计方，用于全局诊断与公平性假设生成（阶段 3、4）。这正是本讲义“让技

术匹配接收方”原则在可解释性上的对应版本：不存在全局默认的解释工具，只有针对具体受众与具体约束的恰当选择。

问题二：公平性与可解释性的相互作用

机制：MCDP 去偏如何改写 SHAP 解释。假设受保护属性（如性别、家庭责任状况）从未被收集，其代理变量是“深夜提交占比”。在 M0 中，该特征与真实风险信号（如圈复杂度）共同驱动预测，并在 SHAP 重要性中占据显著位置。实施 MCDP（在模块类型等合法分组内重加权、约束标记率）后，模型被强制在输出层面切断对代理通路的依赖，于是：

- 全局层面：“深夜提交占比”的 SHAP 重要性排名大幅下滑，其释放的解释权重被重新分配给代码度量（圈复杂度、测试覆盖率等）。
- 局部层面：同一位开发者、同一次代码变更，收到的解释发生了实质变化。下表为示意性对比：

特征（开发者：夜间提交较多，圈复杂度 18，测试覆盖 40%）	M0 下的 SHAP 贡献	MCDP 下的 SHAP 贡献
深夜提交占比（0.6）	+0.35	+0.06
圈复杂度（18）	+0.12	+0.28
测试覆盖率（40%）	+0.20	+0.22
结果	高风险标记	标记撤销或降级

（数值为示意，用于说明结构而非来自具体拟合。）

这一变化带来两个真实后果：

- 解释的不连续性。公司从 M0 切换到 MCDP 之后，开发者收到的“理由”变了——同一段代码从“因为你在深夜提交”变为“因为圈复杂度过高”。如果解释被表述为“你的代码的真实问题所在”，那么两次解释中至少有一次是误导。
- 残余代理的隐蔽性。若提交频率等其他特征仍与受保护属性相关，去偏后模型可能改经这些残余通路传导偏差，而其 SHAP 值看起来完全无害——这与 Slack 等（2020）对 SHAP/LIME 以及 Xin 等（2025）对 PDP 的对抗性操纵研究指出的是同一个盲区：一个被刻意设计成“解释看起来无害”的模型，与一个恰好长出无害解释的模型，从解释输出上无法区分。

我的判断：这是一种真实存在的张力，但是可以通过治理与沟通的选择加以管理的张力，而不是需要“解决”的矛盾。管理点有两层：

- 沟通层——诚实定位解释的性质。向开发者提供的解释应表述为“模型作出该决定的依据”（decision rationale），而非“你的代码在现实中出缺陷的真实原因”（causal account）。模型从不预测真实原因，它只输出统计关联；MCDP 改变的是公司选择让模型依

据什么来做决策，解释随之改变是定义使然，不是故障。只要在切换模型设计时向受影响者如实告知“解释口径已更新”，不连续性就从“误导”变成了“治理选择的可见痕迹”。

• **治理层——公平性结论的出处与解释工具解耦。**合规结论的来源必须是正式的公平性测试（TOST 审计、分组标记率统计），SHAP 只承担讲义“正确的工作流程”中分配给它的角色：生成关于代理通路的假设、诊断并沟通审计结果、支持个案解释——而绝不充当公平性证明。同时把“为何选 MCDP、放弃了多少准确性”的权衡量化并记录在模型卡中呈报给决策者。

结论：可解释性工具与公平性干预确实会相互改变对方的输出——去偏改写解释，解释也可能被操纵以掩护歧视——但只要组织（1）不把 SHAP 当作公平性证明，（2）不把模型理由包装成因果诊断，（3）在准则切换时主动披露解释口径的变化，这一张力就被限制在了它应有的位置上：它是治理决策的可见痕迹，而非系统的缺陷。

问题三：治理文档设计

为软件缺陷预测系统的部署起草模型治理文档（模型卡）大纲。该文档面向任何审计、接手或批准该模型的人员，也作为开发者申诉流程中的事实依据。

a. 文档大纲（六个部分）

#	章节标题	内容（一句话描述）
1	用途与适用范围	描述系统预测什么、高风险标记如何进入发布门禁、目标用户是谁，并明确禁止用途（不得用于绩效考核、晋升或任何人事决策）。
2	数据说明与隐私评估	记录训练数据来源与时间段、预处理与特征最小化清单、准标标识处理方式，以及重新识别风险评估结论与已应用的隐私保护措施。
3	公平性准则与审计结果	载明选定的公平性准则（MCDP）及选择理由、监管与组织依据、预设审计规程（TOST 等效性边界），以及最近一次审计的结论与置信区间。
4	性能与可解释性	汇报训练/验证/测试集上的准确率与校准度及分组表现、全局 SHAP 摘要与关键输入的 PDP，并记录与已知变量效应曲线的交叉核对结果。
5	解释、申诉与人工复核安排	说明被标记开发者获得的解释形式（阈值化反事实规则）、申诉复核流程、人工干预的触发条件与响应时限。
6	局限性、责任人与复审安排	列出已知失效模式（新型代码风格、数据漂移、极端类别的盲区）、指定全生命周期责任人、复审周期与回滚触发条件。

b. 两个部分与第一章原则的对应

第 3 部分（公平性准则与审计结果）→ 主要对应问责制原则。理由：它把“预先承诺”制度化——审计边界在看到结果之前登记，结论以可复核的统计证据（TOST 结论、置信区间）写进文档，任何内部或外部审查者都能据此追问“当时承诺了什么、实际兑现了什么”。这正对应第一章中问责制原则与“治理、文档记录、预先承诺”的映射：模型卡在此是问责的证据载体——当系统出问题时，它回答的不是“模型表现如何”，而是“谁在何时、基于什么标准放行了这个模型”。

第 5 部分（解释、申诉与人工复核安排）→ 主要对应可争议性原则。理由：可争议性要求受自动化决策影响的个人不仅能够理解结果，还能够对结果发起挑战并得到有效回应。该部分给出的解释形式、申诉入口、人工复核触发条件与时限，直接构成开发者“质疑高风险标记”的可操作通道。它与第 4 部分（透明度）的区别在于站位不同：第 4 部分描述“模型是怎样的”，是面向审查者的单向披露；第 5 部分描述“如果你不同意，你可以做什么、由谁在多长时间回应”，是面向受影响者的双向机制——这正是可争议性区别于一般透明度的核心。

问题四：总结性反思

a. 一项课程局限性与弥合差距所需的额外能力

选取的局限性：准则存在争议。讲义明确指出，哪一项公平性准则是恰当的，归根结底是社会性与政治性决策，而非统计学决策——美国基于信用的车险评分之争是最直接的例证：该评分在每个种族群体内部都具有真实预测力，按精算公平性自身的标准它是“公平”的，但仍引发了 17 个州的调查与数十项限制性立法，因为“应由哪种公平性标准支配这项实践”本身是一个有争议的政治判断，统计上的有效性无法替社会回答“谁应得”的问题。

对软件缺陷预测系统负责的领域专业人士是**工程负责人与 QA 负责人**（与第一章作业的结论一致——他们拥有发布放行权与质量否决权，并对开发者的工作负荷后果承担责任）。要在实践中切实弥合这一差距，他们还需要课程之外的以下知识、技能与组织能力：

- **法律与监管素养。**课程给出了准则的技术定义与检验方法，但没有教如何在《个人信息保护法》第 24 条、劳动就业相关法规与公司用工制度之间划定“合法分组”的边界；负责人需要能与法务、HR 共同判断哪些分组差异会被监管者与员工认定为正当，哪些会被认定为变相歧视。
- **利益相关方协商与决策呈报能力。**准则之争的裁决者是组织及其利益相关方，而不是模型。负责人需要能把“MCDP 相比 M0 多损失多少准确性、换来多大的标记率均衡”这类量化权衡翻译成管理层可裁决的选项，并主持一个让开发者代表参与的决策流程——即讲义所要求的“从业者量化权衡并呈报给决策者，而非自行做出选择”的组织化版本。

- **价值判断的伦理训练。**识别“统计上可辩护”与“规范上正当”之间的缝隙（Kiviat 案例的核心：预测有效不等于定价正当）需要伦理学与社会技术系统的视角，这超出了量化方法的训练范围。
- **承接决策的组织能力。**包括明确的风险偏好声明（组织愿意接受多大的漏检风险换取标记公平）、跨职能治理委员会（技术 + HR + 法务 + 员工代表）、为申诉复核配备的专职人力与预算，以及引入外部独立审计的渠道。没有这些制度承接，单个负责人的判断再好，也无法把“准则争议”的裁决转化为可执行、被组织背书的决定。

b. 三大支柱中，哪一项对我未来的实践影响最深远

我预计是**可解释性**。理由有三：

- **它是另外两根支柱的放大器。**公平性审计需要 PDP 与 SHAP 去发现代理通路（问题二刚刚展示了二者如何相互改变对方的输出）；隐私的透明度义务要求向个人说明“数据如何被用于决策”。没有解释能力，公平性与隐私都会退化为无法对外沟通的内部指标——三大支柱中，可解释性是**唯一**被其他两根支柱直接消费的支柱。
- **它是工程师当下就能兑现的支柱。**公平性的最终裁决依赖监管与社会的持续演化，隐私保护的最大约束来自立法与组织，而可解释性完全在工程流程内部：从模型选型（内在可解释 vs 黑箱加事后解释）到 PDP/SHAP/PFI 的日常诊断，都不需要等待任何外部条件成熟。作为未来的软件工程师，这是我现在写下的每一行建模代码都能直接体现的原则。
- **在我选择的场景中，它同时是信任与可争议性的载体。**缺陷预测系统的受影响者（开发者）与构建者（工程师）同处一个组织，解释的质量直接决定评审团队是否信任标记、被标记者能否有效申诉。没有这一层，公平性约束只是报表里的数字，隐私合规只是法务部的一份文件。

诚实的反面承认：在数据收集规模持续扩张（远程信息处理、IDE 遥测、大模型训练语料）的背景下，隐私很可能成为监管上约束最硬的支柱；而且如果为了满足解释性长期使用精度更低的模型，累积的漏检成本也可能反噬系统的价值。但就“我未来日常实践的选择空间与影响半径”而言，可解释性是三大支柱中最深远的一项——它决定了另外两根支柱的成果能否被看见、被理解、被质疑。